

VULNERABILITY ASSESSMENT & PENETRATION TEST

ReNew Solar Marketing Website

Security Assessment Report — Web, Mobile & API

CONFIDENTIAL. This document contains security findings that could assist an attacker if disclosed. Distribute only to personnel responsible for remediating the systems described. Findings reflect the state of the target as observed on the test date and are not a guarantee of ongoing security.

TARGET APPLICATION

ReNew Solar Marketing Site

REPORT DATE

17 August 2026

PRIMARY TARGET URL

https://re-new-mocha.vercel.app/

ASSESSMENT WINDOW

17 August 2026

SOURCE REPOSITORY

renew @ a4f4020 (main)

ASSESSMENT TYPE

Grey-box — source + live target

HOSTING PLATFORM

Vercel (static edge delivery)

REPORT VERSION

1.1 — Post-remediation

REMEDATION APPLIED

17 August 2026

STATUS

6 of 9 closed · 1 mitigated · 2 accepted

1 Executive Summary

A vulnerability assessment and penetration test was performed against the ReNew Solar marketing website, covering the live production deployment at `re-new-mocha.vercel.app` and its full application source tree. The engagement was requested to cover three domains — **Web, Mobile and API**.

The single most important structural finding is that this application has an **exceptionally small attack surface**. It is a Next.js application built with `output: "export"`, meaning it compiles to pure static HTML, CSS, JavaScript and media assets served from Vercel's edge CDN. It contains **no server-side runtime, no route handlers, no middleware, no server actions, no database and no authentication**. Entire classes of vulnerability that dominate typical VAPT reports — SQL injection, authentication bypass, insecure direct object reference, server-side request forgery, session fixation, privilege escalation — have **no reachable code path in this deployment**.

SCOPE REALITY — PLEASE READ BEFORE SECTION 2

Two of the three requested test domains have **no corresponding asset in existence**. There is no mobile application (no native project, no React Native / Capacitor / Cordova, no PWA manifest or service worker), and there is no application API (zero route handlers, zero server functions, zero backend endpoints). This was verified rather than assumed — the verification evidence is documented in Section 3.

This report therefore does **not** contain invented mobile or API findings. Those sections record what was tested, what was confirmed absent, and what security requirements will apply *at the point those assets are built*.

Within the web scope that does exist, **no critical or exploitable vulnerabilities were identified**. No injection, cross-site scripting, or remote code execution vector was found. No secrets are present in the repository or its git history. Transport security is correctly configured, with HSTS preloading and enforced HTTPS redirection.

The findings that were identified fall into three themes: a **complete absence of HTTP security response headers**, a **business-logic defect in which every enquiry form silently discards user submissions**, and **privacy/compliance gaps around personal data collection**. Dependency scanning surfaced known advisories in build-time packages; these are assessed as non-exploitable in the production deployment but represent genuine supply-chain risk to the build pipeline.

Findings by severity — as tested (v1.0)



POST-REMEDIATION STATUS (V1.1)

4 findings closed and verified · 2 fixed pending deployment · 1 mitigated · 2 accepted by the client.

Dependency advisories are fully resolved (`bun audit` : 0 vulnerabilities). Full detail, including what remains open and why, is in Section 1A.

Overall risk posture

LOW. As a brochure-ware site with no authentication, no session state, no cookies, no payment flow and no server-side processing, the realistic worst-case outcome of the identified issues is defacement-by-framing (clickjacking) or reputational damage from lost sales enquiries — not data breach or system compromise. The static architecture is itself the strongest security control present, and it was chosen deliberately (see `docs/adr/0002-full-static-export.md`).

HIGHEST-IMPACT ITEM

VAPT-02 is not a classical security vulnerability, but it is the finding with the largest real-world consequence. All three enquiry forms — the contact section, the enquiry modal and the savings calculator — collect the user's name, phone number, email and company, display a confirmation, and promise a response "within 24 hours", while transmitting the data **nowhere**. Every sales lead submitted through this site since launch has been silently lost. This should be triaged ahead of every other item in this report.

Update (v1.1): partially mitigated. The response-time commitment has been removed and users are now directed to the published phone number and email, so nobody is promised a callback the site cannot deliver. The endpoint itself was deferred by the client, so form submissions are *still not transmitted*. This remains the highest-priority open item.

1A Remediation Status

Following delivery of version 1.0, remediation was carried out on the same day. This section records what changed, what was verified, and what remains open. The findings in Section 5 are left as originally written — they describe the state at the time of testing — and each now carries a status line.

ID	SEVERITY	FINDING	STATUS	VERIFICATION
VAPT-01	MEDIUM	Security headers absent	FIXED — DEPLOY	Policy authored in <code>vercel.json</code> ; effective only once deployed
VAPT-02	HIGH	Enquiry forms discard submissions	MITIGATED	Response-time promise removed; endpoint deferred by client
VAPT-03	MEDIUM	PII collected without notice or consent	ACCEPTED	Deferred by client , coupled to VAPT-02
VAPT-04	MEDIUM	Vulnerable build-time dependencies	CLOSED	<code>bun audit : 0 vulnerabilities</code> after clean install
VAPT-05	LOW	Wildcard CORS	FIXED — DEPLOY	Scoped to a single origin in <code>vercel.json</code>
VAPT-06	LOW	No disclosure channel or crawler directives	CLOSED	All three files generated and present in the build output
VAPT-07	INFO	JSON-LD sink unescaped	CLOSED	Escape applied; verified in built HTML
VAPT-08	INFO	No Subresource Integrity	NO ACTION	Correctly no-op — still zero third-party scripts
VAPT-09	INFO	PDF authoring-tool metadata	ACCEPTED	Optional; no sensitive data was present

1A.1 Changes applied

FILE	CHANGE	EFFECT
vercel.json	New	CSP with <code>frame-ancestors 'none'</code> , X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, COOP, CORP, scoped CORS
package.json	Modified	<code>next</code> → 16.2.11; overrides forcing patched <code>postcss</code> , <code>nanoid</code> , <code>brace-expansion</code> , <code>js-yaml</code> , <code>sharp</code>
public/.well-known/security.txt	New	RFC 9116 disclosure channel — <code>security@renew.com</code>
src/app/robots.ts	New	Generates <code>robots.txt</code> at build
src/app/sitemap.ts	New	Generates <code>sitemap.xml</code> for the six public routes
src/lib/site.ts	New	Canonical origin, overridable by env var for the domain move
src/app/page.tsx	Modified	<code><</code> escaped in the JSON-LD sink
src/components/sections/contact.tsx	Modified	24-hour promise removed; users directed to phone and email
src/components/contact-modal.tsx	Modified	Same, plus tappable contact links in the confirmation
next.config.ts	Modified	Dev origin read from <code>DEV_ORIGIN</code> instead of a committed IP

NOT YET VERIFIED IN PRODUCTION

VAPT-01 and VAPT-05 are fixed in configuration but unverified in production. `vercel.json` is applied by the hosting platform at deploy time, so the headers cannot take effect — or be confirmed — until the change is deployed. Both remain formally open until the retest in Section 7.1 passes against the live host. No deployment was performed as part of this remediation.

ACCEPTED RISKS — CLIENT DECISION

Three items were explicitly deferred by the client and are recorded as accepted rather than resolved:

- **VAPT-02** — the submission endpoint. The interim mitigation stops users being given a commitment the site cannot keep, but enquiries submitted through the form are still not transmitted. The direct phone and email are now the only routes that reach the team, and they are surfaced in the form's confirmation.
- **VAPT-03** — privacy notice and consent. This remains correctly coupled to VAPT-02: because no personal data is transmitted or stored, there is no processing to be non-compliant about. **The moment an endpoint goes live, this becomes an active DPDP obligation and must ship with it.**
- **VAPT-09** — PDF metadata stripping. Low value; no author names, internal paths or usernames were present.

2 Scope & Rules of Engagement

2.1 Assets in scope

DOMAIN	ASSET	STATUS	BASIS OF ASSESSMENT
Web	<code>https://re-new-mocha.vercel.app/</code> and all sub-routes	TESTED	Live black-box probing plus full source review
Web	Application source — <code>renew</code> repo @ <code>a4f4020</code>	TESTED	Static analysis, secret scanning, git history review
Web	Third-party dependency tree (15 direct packages)	TESTED	SCA against GitHub Advisory Database
API	Application API endpoints	NOT PRESENT	Absence verified — see Section 3.2
Mobile	iOS / Android / hybrid application	NOT PRESENT	Absence verified — see Section 3.3

2.2 Explicitly out of scope

- **Vercel platform infrastructure** — the hosting provider's edge network, TLS termination and control plane are the provider's responsibility and were not tested.
- **Third-party destinations linked from the site** — `renew.com`, `warranty.renew.com`, `renew.freshdesk.com` and social media properties are separate systems under separate ownership. They were *not* probed.
- **Denial-of-service and load testing** — excluded by convention; the target is a CDN-fronted static site where DoS resistance is a platform property.
- **Social engineering and physical security** — not requested.
- **The corporate `renew.com` production domain** — this assessment covers the Vercel preview/staging deployment only.

2.3 Rules of engagement observed

Testing was **non-destructive and non-disruptive** throughout. All live interaction was limited to standard HTTP requests: header inspection, path enumeration against a small wordlist of well-known sensitive paths, and retrieval of publicly served assets. No automated vulnerability scanner, fuzzer, brute-force tool or exploit was run against the live host. No data was modified, and no denial-of-service condition was induced. Request volume remained within normal browsing levels.

2.4 Methodology & standards

The assessment followed a grey-box methodology aligned to the following frameworks:

- **OWASP Web Security Testing Guide (WSTG) v4.2** — web test case coverage

- **OWASP Top 10:2021** — web risk categorisation
- **OWASP API Security Top 10:2023** — applied to the API scope determination
- **OWASP Mobile Application Security Verification Standard (MASVS) v2** — applied to the mobile scope determination
- **CWE** — weakness classification; **CVSS v3.1** — severity scoring

Phases executed: reconnaissance and asset discovery → configuration and deployment review → static source analysis → software composition analysis → live control verification → risk analysis and reporting.

2.5 Risk rating framework

RATING	CVSS V3.1	DEFINITION APPLIED IN THIS REPORT
CRITICAL	9.0 – 10.0	Trivially exploitable, leads to full system or data compromise. Fix immediately.
HIGH	7.0 – 8.9	Direct, material impact on confidentiality, integrity, availability, or core business function.
MEDIUM	4.0 – 6.9	Meaningful weakening of security posture; typically requires a precondition or user interaction.
LOW	0.1 – 3.9	Limited impact; defence-in-depth or hardening value.
INFO	0.0 / N/A	No present risk. Recorded for awareness or to prevent future regression.

A NOTE ON SCORING HONESTY

Severities in this report are **environmentally adjusted** — rated for this deployment, not for the theoretical worst case. Where an upstream advisory carries a high base score but the vulnerable code path is unreachable in a static export, both the upstream score and the adjusted score are shown, with the reasoning stated. Inflating such findings to match a scanner's raw output would misdirect remediation effort.

3 Attack Surface Determination

Before testing, the actual attack surface was established from first principles. This section documents that determination, because it is the basis on which large parts of a conventional VAPT checklist are marked not-applicable rather than passed.

3.1 Web application architecture

The application is Next.js 16.2.10 configured for static export. The relevant configuration is unambiguous:

```
// next.config.ts
const nextConfig: NextConfig = {
  // Pure static export – see docs/adr/0002-full-static-export.md
  output: "export",
  allowedDevOrigins: ["192.168.18.157"],
  images: { unoptimized: true, qualities: [75, 90] },
  reactCompiler: true,
};
```

The consequences for security testing are as follows:

CAPABILITY	PRESENT	CONSEQUENCE
Server-side request handling	NO	No SSRF, no server-side injection, no deserialisation
Route handlers / API routes	NO	No API attack surface (Section 3.2)
Middleware	NO	No middleware bypass; no auth layer to bypass
Server Actions	NO	Next.js Server Action advisories unreachable
Image Optimization API	NO	unoptimized: true — optimizer advisories unreachable
Database / persistence	NO	No SQL/NoSQL injection, no data at rest
Authentication / sessions	NO	No broken auth, no session handling, no privilege model
Cookies	NO	No CSRF surface, no cookie attribute findings
File upload	NO	No unrestricted upload vector
Client-side rendering & DOM	YES	DOM XSS reviewed — see VAPT-07
User input collection	YES	Three forms — see VAPT-02, VAPT-03
Static asset delivery	YES	Headers, CORS, exposure — VAPT-01, 05, 06, 09

3.2 API scope — verification of absence

The requested API assessment has no target. This was confirmed by four independent checks across source and the live host, all negative:

SOURCE-SIDE VERIFICATION

```
# 1. No route handlers anywhere in the source tree

→ (only .next/server/app/favicon.ico/route.js – a build artifact for the favicon)

# 2. No middleware

→ (no results)

# 3. No app/api directory

→ (no results)

# 4. No outbound calls from client code – no fetch, axios, or XHR

→ (no results)
```

LIVE-SIDE VERIFICATION

404

CONCLUSION – API

No application API exists. The site performs zero network requests beyond fetching its own static assets. The OWASP API Security Top 10:2023 categories — broken object-level authorisation, broken authentication, unrestricted resource consumption, and the remainder — are **not applicable**, as there is no endpoint to which they could apply. Requirements for the API that *will* be needed to fix VAPT-02 are set out in Section 6.

3.3 Mobile scope — verification of absence

The requested mobile assessment likewise has no target:

```
# No native project directories

→ no native/mobile project dirs

# No hybrid/cross-platform framework in dependencies or source

→ CONFIRMED: no mobile frameworks

# No PWA installability surface – no manifest, no service worker

→ (no results)

# Full dependency list – 15 packages, none mobile-related
```

CONCLUSION — MOBILE

No mobile application exists in any form: no native iOS or Android project, no hybrid wrapper, and not even an installable Progressive Web App. There is no binary to reverse, no local storage to inspect, no certificate pinning to evaluate and no IPC surface to test. OWASP MASVS is **not applicable**.

Mobile *browser* access to the responsive website is covered by the web assessment — the same static assets are served to every client regardless of device, so there is no mobile-specific server behaviour to test separately.

3.4 Discovered web surface

Routes confirmed live (HTTP 200) during enumeration:

ROUTE	STATUS	FUNCTION & INPUT SURFACE
/	200	Homepage — 12 sections; contains contact form and savings calculator
/manufacturing	200	Content page — no input
/projects	200	Content page — no input
/products/solar-module	200	Content page — no input
/products/solar-cell	200	Content page — no input
/downloads	200	Serves 16 public PDF documents — see VAPT-09
/_next/static/*	200	Immutable JS/CSS bundles

Sensitive-path probing returned HTTP 404 for `/.env`, `/.git/config`, `/package.json`, `/robots.txt`, `/sitemap.xml` and `/.well-known/security.txt`.

4 Findings Summary

ID	SEVERITY	FINDING	CATEGORY	DOMAIN
VAPT-02	HIGH	Enquiry forms silently discard all user submissions	Business logic	Web
VAPT-01	MEDIUM	HTTP security response headers entirely absent	Misconfiguration	Web
VAPT-03	MEDIUM	Personal data collected with no privacy notice or consent	Privacy / compliance	Web
VAPT-04	MEDIUM	Known vulnerabilities in build-time dependencies	Supply chain	Build
VAPT-05	LOW	Wildcard <code>Access-Control-Allow-Origin</code> on all responses	Misconfiguration	Web
VAPT-06	LOW	No vulnerability disclosure channel (<code>security.txt</code>)	Process	Web
VAPT-07	INFO	<code>dangerouslySetInnerHTML</code> used for JSON-LD injection	Code hygiene	Web
VAPT-08	INFO	No Subresource Integrity on script tags	Hardening	Web
VAPT-09	INFO	Authoring-tool version disclosure in published PDF metadata	Info disclosure	Web

4.1 Controls verified as effective

The following were explicitly tested and **passed**. They are recorded so that a future change does not silently regress them.

CONTROL	RESULT	EVIDENCE
HSTS with preload	PASS	<code>max-age=63072000; includeSubDomains; preload</code> — 2-year max-age, correctly formed
HTTPS enforcement	PASS	Plain HTTP returns <code>308</code> permanent redirect to HTTPS
TLS certificate validity	PASS	<code>ssl_verify_result=0</code> ; HTTP/2 negotiated
Reverse tabnabbing	PASS	All 5 <code>target="_blank"</code> links carry <code>rel="noopener noreferrer"</code>
Secrets in source	PASS	No API keys, tokens or credentials; <code>process.env</code> never referenced in <code>src/</code>
Secrets in git history	PASS	No <code>.env</code> , <code>.pem</code> , <code>.key</code> or credential file ever committed across all branches
Source map exposure	PASS	<code>.map</code> request returns <code>403</code> ; no <code>sourceMappingURL</code> in shipped bundles
Sensitive file exposure	PASS	<code>/.env</code> , <code>/.git/config</code> , <code>/package.json</code> all return <code>404</code>
Third-party script supply chain	PASS	Zero external scripts — no analytics, tag manager, or tracker loaded
Injection sinks (XSS)	PASS	No <code>eval</code> , <code>new Function</code> , <code>innerHTML</code> or <code>document.write</code> in <code>src/</code>
Directory listing	PASS	No traversable index exposed on static paths
Cookie security	PASS	No <code>Set-Cookie</code> issued — no cookie attack surface at all

5 Detailed Findings

VAPT-02 **Enquiry forms silently discard all user submissions**

HIGH

CVSS V3.1	CWE	OWASP	DOMAIN
N/A — business logic	CWE-670 — Always-Incorrect Control Flow	A04:2021 — Insecure Design	Web — client-side

DESCRIPTION

All three data-collection forms on the site handle submission entirely in the browser. Each one calls `preventDefault()`, flips a local React state flag to render a success confirmation, and then does nothing further. The collected data is never transmitted, never persisted, and is discarded the moment the page unloads.

Because the application is a static export with no server component, there is no endpoint that could receive the submission even in principle — this is confirmed by the developer's own `TODO` comment left in the contact section.

AFFECTED COMPONENTS

FILE	LINE	DATA COLLECTED
src/components/sections/contact.tsx	105–120	name, company, phone, state, requirement
src/components/contact-modal.tsx	284–287	name, company, phone, email , requirement
src/components/sections/savings-calculator.tsx	117–120	state, electricity bill amount

EVIDENCE

```
// src/components/sections/contact.tsx:105
/* TODO(batch-4-followup): external form endpoint – static export has no
  server; submission currently just confirms locally. */
<form
  onSubmit={(e) => {
    e.preventDefault();
    setSubmitted(true);    // ← the entire submission handler
  }}
>
```

The user-facing copy directly beside this form makes an explicit commitment:

```
"Tell us what you need and our team will get back to you within 24 hours."
    – src/components/sections/contact.tsx:88
```

IMPACT

- **Total loss of inbound sales leads.** Every enquiry submitted since the site went live has been discarded. For a marketing site whose primary conversion goal is lead capture, this defeats the purpose of the asset.
- **Misrepresentation to the user.** A prospective customer submits personal data, receives a success confirmation and an explicit 24-hour response promise, and is never contacted. This is a consumer-trust and potentially a consumer-protection concern, independent of the security question.
- **Deferred security debt.** When a submission endpoint is added, it will introduce the site's first genuine server-side attack surface. None of the controls that endpoint will require — input validation, rate limiting, anti-

automation, output encoding, transport of PII to a CRM — currently exist.

REMEDIATION

Wire the forms to a real endpoint, and treat that endpoint as a new security boundary from day one. Given the static-export constraint, the options in ascending order of control are:

1. **Third-party form backend** (Formspree, Basin, Web3Forms) — fastest; verify the provider's data residency, since Indian personal data is involved.
2. **Vercel Serverless Function** — a function placed in `api/` is deployed by Vercel independently of the Next.js static export, preserving the current architecture. This is the recommended option.
3. **Direct CRM integration** — post to the existing `renew.freshdesk.com` instance already linked in the footer, keeping leads in the system the sales team uses.

Whichever is chosen, the endpoint must implement:

- Server-side validation and length limits on every field (never trust the client)
- Rate limiting per IP and anti-automation (CAPTCHA or equivalent) — a public, unauthenticated form is an immediate spam and abuse target
- An explicit origin allow-list rather than wildcard CORS
- Encoding of all field values before they reach any downstream consumer (email body, CRM ticket, admin dashboard) to prevent stored XSS and email header injection
- A genuine failure path in the UI — the success state must reflect a real server acknowledgement, not an unconditional local flag

INTERIM ACTION

Until an endpoint is live, the promise of a 24-hour response should be removed and users directed to the already-published contact details (`pv.marketing@renew.com` / 9220 440 044), so that enquiries are not lost while the fix is built.

VAPT-01 HTTP security response headers entirely absent

MEDIUM

CVSS V3.1	VECTOR	CWE	OWASP
4.3 — Medium	AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N	CWE-1021, CWE-693	A05:2021 — Security Misconfiguration

DESCRIPTION

The application returns no security-relevant response headers other than `Strict-Transport-Security`. Content Security Policy, framing protection, MIME-sniffing protection, referrer control and permissions policy are all missing across every route tested.

EVIDENCE

```
HTTP/2 200
accept-ranges: bytes
access-control-allow-origin: *
cache-control: public, max-age=0, must-revalidate
content-type: text/html; charset=utf-8
server: Vercel
strict-transport-security: max-age=63072000; includeSubDomains; preload  + present

NONE 0F: CSP / X-Frame-Options / X-Content-Type-Options / Referrer-Policy / Permissions-Policy
```

HEADER	STATUS	CONSEQUENCE OF ABSENCE
Content-Security-Policy	MISSING	No defence-in-depth against XSS; no framing control; no restriction on where scripts may load from
X-Frame-Options	MISSING	Site can be framed by any origin — clickjacking and UI-redress attacks are possible
X-Content-Type-Options	MISSING	Browsers may MIME-sniff responses, notably the 16 user-downloadable PDFs
Referrer-Policy	MISSING	Full URLs leak to the six external destinations linked from the site
Permissions-Policy	MISSING	Camera, microphone, geolocation and other powerful features are not explicitly denied
Strict-Transport-Security	PRESENT	Correctly configured — no action needed

IMPACT

The realistic risk here is **clickjacking**. Because no framing restriction exists, an attacker can embed the ReNew Solar site in a hidden or transparent iframe on a hostile page and overlay it with their own interface — for example, capturing enquiry-form keystrokes on a page that appears to be an unrelated offer, or presenting a

fraudulent "ReNew Solar dealer registration" wrapper that borrows the site's visual legitimacy. For a brand-facing marketing property, the damage is reputational rather than technical.

The absence of CSP does not itself create a vulnerability — no injection sink was found — but it removes the safety net that would contain one if a future change introduced it.

REMEDIATION

IMPORTANT — DEPLOYMENT-SPECIFIC DETAIL

The `headers()` function in `next.config.ts` has no effect when **output: "export"** is set, because there is no Next.js server to apply it. Headers must be configured at the Vercel platform layer instead. Adding them to `next.config.ts` would appear to fix this finding while changing nothing in production.

Create `vercel.json` at the repository root:

```
{
  "headers": [
    {
      "source": "/(.*)",
      "headers": [
        { "key": "X-Frame-Options", "value": "DENY" },
        { "key": "X-Content-Type-Options", "value": "nosniff" },
        { "key": "Referrer-Policy", "value": "strict-origin-when-cross-origin" },
        { "key": "Permissions-Policy",
          "value": "camera=(), microphone=(), geolocation=(), payment=(), usb=()" },
        { "key": "Content-Security-Policy",
          "value": "default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self'
'unsafe-inline'; img-src 'self' data: blob;; media-src 'self'; font-src 'self' data;; connect-src
'self'; frame-ancestors 'none'; form-action 'self'; base-uri 'self'; object-src 'none'; upgrade-
insecure-requests" }
      ]
    }
  ]
}
```

This policy is achievable today because every script and style on the site is first-party — the assessment confirmed zero external script origins. `'unsafe-inline'` is required for the inline bootstrap and JSON-LD blocks Next.js emits; it can be tightened to a nonce- or hash-based policy later, but the policy above already delivers the framing and object-source protections that matter most here. Validate with a report-only rollout (`Content-Security-Policy-Report-Only`) before enforcing.

VAPT-03 **Personal data collected with no privacy notice or consent**

MEDIUM

CVSS V3.1	CWE	OWASP	REGULATION
N/A — compliance	CWE-359 — Exposure of Private Information	A04:2021 — Insecure Design	India DPDP Act, 2023

DESCRIPTION

The site collects personally identifiable information through three forms, but publishes no privacy policy, no notice of purpose, no consent mechanism and no data-retention statement. A full-text search of the source found no occurrence of the words *privacy*, *terms*, *consent*, *cookie*, *GDPR* or *DPDP* anywhere in the application, and the footer contains no policy link.

EVIDENCE

NONE FOUND

Personal data fields identified across the three forms:

FIELD	CATEGORY	COLLECTED IN
name	Identifier	Contact section, enquiry modal
email	Contact identifier	Enquiry modal
phone	Contact identifier	Contact section, enquiry modal
company	Employment data	Contact section, enquiry modal
state	Coarse location	Contact section, savings calculator
requirement	Commercial intent	Contact section, enquiry modal
bill amount	Financial indicator	Savings calculator

IMPACT

ReNew is an Indian company processing the personal data of Indian data principals, which brings the **Digital Personal Data Protection Act, 2023** into effect. The Act requires a clear notice at or before the point of collection, describing the personal data collected, the purpose of processing, and the mechanism for withdrawing consent and lodging a complaint. None of that is present.

The exposure is currently mitigated by an unusual circumstance: because of VAPT-02, the data is never actually transmitted or stored, so there is no processing to be non-compliant about. **Fixing VAPT-02 without fixing this finding converts a latent compliance gap into an active one** — the two must be remediated together.

REMEDIATION

- Publish a privacy policy covering the fields above, and link it from the footer and from each form.
- Add an explicit, unticked consent checkbox to every form, with text naming the purpose — for example, contact regarding a solar enquiry.

- Define and document a retention period for enquiry data, and a deletion process.
- Publish a grievance contact, as required by the DPDP Act.
- If a third-party form backend is selected for VAPT-02, confirm its data residency and record it in the policy.

This finding identifies a compliance gap from a technical assessment; it is not legal advice. Confirm the specific obligations with ReNew's legal or data-protection function.

VAPT-04 Known vulnerabilities in build-time dependencies**MEDIUM****ADJUSTED SEVERITY**

Medium (build pipeline)

UPSTREAM MAX

High

CWECWE-1395 — Vulnerable
Dependency**OWASP**A06:2021 — Vulnerable
Components**DESCRIPTION**

Software composition analysis identified known advisories affecting five packages in the dependency tree, including the pinned framework version `next@16.2.10`.

EVIDENCE

PACKAGE	INSTALLED	UPSTREAM	FIXED IN	REACHABLE IN PRODUCTION?
next	16.2.10	HIGH	16.2.11	No — all 9 advisories require Server Actions, middleware, rewrites or the Image Optimization API; none exist here
postcss	8.4.31 (nested under next)	HIGH	8.5.23	No — build-time CSS processing only; never executes in the browser
sharp	0.34.5 (nested under next)	HIGH	0.35.0+	No — <code>images.unoptimized: true</code> ; the top-level install is already 0.35.3
nanoid	3.3.15	HIGH	3.3.16	No — transitive via postcss; build-time only
brace-expansion	1.1.16	HIGH	1.1.17	No — transitive via eslint; development tooling only

The nine Next.js advisories affecting `16.2.10`, with applicability:

ADVISORY	ISSUE	APPLIES HERE
GHSA-89xv-2m56-2m9x	SSRF in Server Actions on custom servers	No — no Server Actions, no custom server
GHSA-p9j2-gv94-2wf4	SSRF via attacker-controlled rewrite destination	No — no rewrites configured
GHSA-6gpp-xcg3-4w24	Middleware / proxy bypass (Turbopack, single locale)	No — no middleware
GHSA-m99w-x7hq-7vfj	DoS in App Router via Server Actions	No — no Server Actions
GHSA-955p-x3mx-jcvp	Unauthenticated disclosure of internal Server Function endpoints	No — no server functions
GHSA-q8wf-6r8g-63ch	DoS in Image Optimization API via SVG	No — optimizer disabled
GHSA-68g3-v927-f742	Cache confusion for requests with bodies	No — static assets only
GHSA-4633-3j49-mh5q	Cache confusion, invalid UTF-8 bodies	No — static assets only
GHSA-4c39-4ccg-62r3	Unbounded Server Action payload, Edge runtime	No — no Edge runtime in use

IMPACT

Production risk is assessed as negligible. Every advisory above requires a server-side execution context that this deployment does not have. A scanner run against `package.json` alone will report these as High; that raw output overstates the risk to the live site, and remediating on that basis would misallocate effort.

Build-pipeline risk is real, however. The PostCSS path-traversal and arbitrary `.map` file-read advisories execute at build time with the privileges of the CI runner or the developer's workstation. If a malicious CSS file ever entered the build — through a dependency update, a design-tool export, or a contributed stylesheet — those advisories become directly relevant to the machine performing the build. Vulnerable build tooling is a supply-chain exposure even when the shipped artifact is clean.

REMEDIATION

```
# Patch release — no breaking changes expected from 16.2.10 → 16.2.11

# picks up postcss, nanoid, brace-expansion fixes
# confirm the tree is clean
# verify the static export still produces correct output
```

- Upgrading `next` to `16.2.11` resolves the framework advisories and refreshes its nested `postcss` and `sharp` copies.
- Enable Dependabot or Renovate on the repository so patch-level security updates are proposed automatically rather than discovered at audit time.
- Add `bun audit` as a non-blocking CI step to give continuous visibility.
- Re-evaluate this finding's severity upward to **High** if the application ever gains a server-side runtime — the advisories become reachable at that moment.

VAPT-05 Wildcard Access-Control-Allow-Origin on all responses**LOW**

CVSS V3.1

3.1 — Low

CWE

CWE-942 — Permissive CORS Policy

OWASP

A05:2021 — Misconfiguration

DOMAIN

Web — platform config

DESCRIPTION

Every response, including HTML documents and JavaScript bundles, carries `access-control-allow-origin: *`, permitting any origin on the internet to read the response body via cross-origin JavaScript.

EVIDENCE

```
access-control-allow-origin: *
cache-control: public,max-age=31536000,immutable
content-type: application/javascript; charset=utf-8
```

IMPACT

Minimal in the current design. A permissive CORS policy is dangerous when it exposes authenticated or user-specific responses, because an attacker's page can read them using the victim's credentials. Neither precondition holds here: the site issues no cookies, has no authentication, and serves byte-identical public marketing content to every visitor. An attacker gains nothing by reading cross-origin what they can already fetch directly.

It is reported because it is a latent misconfiguration. If an authenticated area, a personalised response, or a form-handling endpoint is ever added under this configuration, the same wildcard would then expose genuinely sensitive data. It also makes content-scraping and asset hot-linking marginally easier.

REMEDIATION

Remove the wildcard on document responses and scope it to the assets that legitimately need cross-origin access — in practice, fonts and media. Add to the `vercel.json` created for VAPT-01:

```
{
  "headers": [
    { "source": "/*.*",
      "headers": [ { "key": "Access-Control-Allow-Origin", "value": "" } ] },
    { "source": "/*_next/static/*.*",
      "headers": [ { "key": "Access-Control-Allow-Origin", "value": "https://re-new-mocha.vercel.app" } ] }
  ]
}
```

Verify in a preview deployment before promoting — fonts and media in particular will fail to load if the allow-list omits an origin they are fetched from. When a submission endpoint is added under VAPT-02, that endpoint must use an explicit origin allow-list and must never inherit a wildcard.

VAPT-06 No vulnerability disclosure channel or crawler directives

LOW

CVSS V3.1	CWE	STANDARD	DOMAIN
N/A — process	CWE-1059 — Insufficient Documentation	RFC 9116	Web — process

DESCRIPTION

The site publishes neither a `security.txt` file nor a `robots.txt` or `sitemap.xml`.

EVIDENCE



IMPACT

A security researcher who discovers a flaw in this site has no documented way to report it. In practice, undirected reports go to a generic marketing inbox, get treated as spam, and either go unactioned or are eventually disclosed publicly. The absence of `robots.txt` and `sitemap.xml` carries no security consequence for a site with nothing to hide, but it is a missed SEO control on a marketing asset whose purpose is discoverability.

REMEDIATION

Add `public/.well-known/security.txt` — it is copied verbatim into the static export:

```
Contact: mailto:security@renew.com
Expires: 2027-08-17T00:00:00.000Z
Preferred-Languages: en, hi
Canonical: https://re-new-mocha.vercel.app/.well-known/security.txt
```

Confirm the contact address is monitored by someone able to triage a security report before publishing it. The `Expires` field is mandatory under RFC 9116 and must be kept current. Add `public/robots.txt` and a generated `sitemap.xml` alongside it for SEO.

VAPT-07 **dangerouslySetInnerHTML** used for JSON-LD injection

INFO

CVSS V3.1

0.0 — not exploitable

CWE

CWE-79 — XSS (latent)

OWASP

A03:2021 — Injection

DOMAIN

Web — client-side

DESCRIPTION

The homepage injects its Schema.org organisation markup using `dangerouslySetInnerHTML`. This is the only use of a raw HTML sink anywhere in the codebase.

EVIDENCE

```
// src/app/page.tsx:33
<script
  type="application/ld+json"
  dangerouslySetInnerHTML={{ __html: JSON.stringify(organizationSchema) }}
/>
```

IMPACT

Not exploitable as written. The `organizationSchema` object is a hard-coded constant declared 15 lines above the sink, containing only static company description strings. No user input, URL parameter, or external data reaches it, so there is no injection vector.

It is recorded for one specific reason: `JSON.stringify` does **not** escape the sequence `</script>`. Should this schema ever be made dynamic — populated from a CMS, a product feed, or a URL parameter — an attacker able to influence any string within it could break out of the script element and achieve stored XSS. The vulnerable pattern is already in place; only the untrusted data source is missing.

REMEDIATION

No urgent action required. When touching this code, escape the sink defensively:

```
const safeSchema = JSON.stringify(organizationSchema).replace(/</g, "\\u003c");

<script
  type="application/ld+json"
  dangerouslySetInnerHTML={{ __html: safeSchema }}
/>
```

Treat any future change that makes this data dynamic as a security-relevant change requiring review. The `frame-ancestors` and `object-src` directives in the VAPT-01 CSP provide additional containment.

VAPT-08 No Subresource Integrity on script tags

INFO

CVSS V3.1	CWE	OWASP	DOMAIN
0.0 — informational	CWE-353 — Missing Integrity Check	A08:2021 — Integrity Failures	Web — client-side

DESCRIPTION & IMPACT

None of the eleven script elements on the homepage carry an `integrity` attribute. However, **all of them are first-party**, served from the same origin under `/_next/static/`, and the site loads no external scripts whatsoever — no analytics, no tag manager, no font or widget CDN.

SRI exists to detect tampering with resources fetched from a third party. With no third-party resources in the page, it provides essentially no protection here: an attacker who could modify same-origin assets could equally modify the integrity hashes in the HTML that references them. This is recorded as informational rather than actionable.

REMEDIATION

No action needed in the current architecture. This becomes a genuine requirement the moment any external script is added — an analytics tag, a chat widget, or a font loader. At that point, apply `integrity` and `crossorigin` attributes to the external tag, and tighten the CSP `script-src` directive from VAPT-01 to name the new origin explicitly rather than relaxing it to a wildcard.

VAPT-09 **Authoring-tool version disclosure in published PDF metadata**

INFO

CVSS V3.1	CWE	OWASP	DOMAIN
0.0 — informational	CWE-200 — Information Exposure	A01:2021 — Access Control	Web — content

DESCRIPTION

The `/downloads` route publishes 16 PDF documents — certificates, product datasheets, an installation manual, a warranty document and a corporate brochure. Their embedded metadata discloses the authoring software and version used to produce them.

EVIDENCE

```
/Creator(Adobe InDesign 21.4 (Windows))
/Producer(Adobe PDF Library 18.0)

/Creator(Adobe InDesign 20.4 (Windows))
/Producer(Adobe PDF Library 17.0)
```

IMPACT

Very low. The metadata was checked specifically for the disclosures that matter — author names, internal usernames, network paths and internal server names — and **none were present**. What remains is software version disclosure, which tells an attacker only that the marketing team uses Adobe InDesign on Windows. It offers marginal value for a targeted phishing pretext against that team and nothing more.

All 16 documents were confirmed to be intentionally public marketing collateral. No internal, confidential or unlisted document was found in the published set.

REMEDIATION

Optional. If desired, strip metadata as a publishing step before adding documents to `public/downloads/` :

The more durable control is process: confirm that documents placed in `public/` are cleared for public release, since everything in that directory is served without access control. That review is more valuable than the metadata stripping itself.

6 Security Requirements for Planned Assets

Because the API and mobile scopes have no current target, the constructive equivalent of a findings list is a set of requirements to apply when those assets are built. These are recommendations, not findings, and carry no severity.

6.1 When the form-submission API is built (required by VAPT-02)

This endpoint will be the site's first server-side attack surface and its first handler of personal data. It should be built against OWASP API Security Top 10:2023 from the outset:

CONTROL	REQUIREMENT
Input validation	Server-side schema validation with strict types and length caps on every field. Reject rather than sanitise.
Rate limiting	Per-IP and global throttling. A public unauthenticated form is targeted by automated spam within days of going live. (API4:2023)
Anti-automation	CAPTCHA, proof-of-work, or an equivalent bot control.
Output encoding	Encode every field before it reaches an email body, CRM ticket, or admin view — prevents stored XSS and email header injection.
CORS	Explicit origin allow-list. Never the wildcard inherited from VAPT-05.
Transport & storage	TLS in transit; encryption at rest; documented retention aligned to the VAPT-03 privacy policy.
Secrets management	CRM and provider credentials in Vercel environment variables. Never in the repository, and never in a <code>NEXT_PUBLIC_</code> variable, which is inlined into client bundles.
Error handling	Generic client-facing errors; detailed logs server-side only. No stack traces to the browser.
Logging	Log submissions for abuse detection, but exclude or mask the personal data fields themselves.

6.2 If a mobile application is developed

Should ReNew Solar later build a customer or channel-partner mobile app, it should be assessed against **OWASP MASVS v2**. The controls that would matter most for an app in this domain — likely handling dealer accounts, warranty registration or installation records:

- **MASVS-STORAGE** — no PII, tokens or credentials in plaintext preferences, local databases, or logs; use Keychain and Keystore.
- **MASVS-CRYPTO** — platform cryptography only; no hard-coded keys in the binary.
- **MASVS-AUTH** — server-side enforcement of every authorisation decision; treat the client as untrusted.
- **MASVS-NETWORK** — TLS enforced, certificate validation never disabled in release builds, and certificate pinning considered for the account and warranty flows.

- **MASVS-PLATFORM** — guard exported components, deep links and WebView configuration; disable JavaScript bridges unless required.
- **MASVS-CODE** — no debug builds shipped, no verbose logging in release, and dependency scanning in the mobile pipeline.
- **MASVS-RESILIENCE** — obfuscation and anti-tampering, proportionate to the sensitivity of what the app handles.

6.3 Architectural guidance

PRESERVE THE STATIC EXPORT

The current architecture is the single strongest security control this application has. It eliminates entire vulnerability classes by construction rather than by defence. When the form endpoint is added, implement it as a **discrete serverless function** rather than by converting the site to a server-rendered deployment. That keeps the server-side attack surface confined to one small, reviewable, single-purpose endpoint instead of extending it across every route — and it keeps the Next.js advisories in VAPT-04 unreachable.

7 Remediation Roadmap

Ordered by a combination of business impact, exploitability and implementation cost.

#	ID	ACTION	PRIORITY	EFFORT	OWNER
1	VAPT-02	Remove the unsupported 24-hour response promise; direct users to the published email and phone contact	IMMEDIATE	< 1 hour	Frontend
2	VAPT-01	Add <code>vercel.json</code> with CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy	IMMEDIATE	2–3 hours	DevOps
3	VAPT-04	Upgrade <code>next</code> to 16.2.11 and refresh the dependency tree; verify the build	1 WEEK	1–2 hours	Frontend
4	VAPT-02	Build the form-submission endpoint per the Section 6.1 control set	2 WEEKS	2–3 days	Backend
5	VAPT-03	Publish the privacy policy and add consent controls — must ship with or before item 4	2 WEEKS	1 day + legal	Legal / Frontend
6	VAPT-05	Scope <code>Access-Control-Allow-Origin</code> away from the wildcard	1 MONTH	1 hour	DevOps
7	VAPT-06	Publish <code>security.txt</code> , <code>robots.txt</code> and <code>sitemap.xml</code>	1 MONTH	1 hour	DevOps
8	VAPT-04	Enable Dependabot/Renovate and add <code>bun audit</code> to CI	1 MONTH	2 hours	DevOps
9	VAPT-07	Escape the JSON-LD sink when next touching <code>page.tsx</code>	OPPORTUNISTIC	10 min	Frontend
10	VAPT-09	Add PDF metadata stripping to the asset publishing process	OPPORTUNISTIC	30 min	Marketing

SEQUENCING DEPENDENCY

Items 4 and 5 are coupled. Shipping the working form endpoint *before* the privacy notice would begin real processing of personal data without the notice and consent the DPDP Act requires — converting a currently latent compliance gap into an active one. Ship item 5 first, or ship both together.

7.1 Retest guidance

A focused retest is recommended once items 1–5 are complete. The following checks confirm remediation:

```
# VAPT-01 – headers now present

# VAPT-01 – clickjacking no longer possible: expect frame-ancestors 'none'
# VAPT-04 – dependency tree clean

# VAPT-05 – wildcard removed from document responses

# VAPT-06 – disclosure channel published
```

VAPT-02 and VAPT-03 require functional verification rather than a header check: submit a test enquiry and confirm it arrives in the destination system, confirm the UI surfaces a genuine error when the endpoint is unavailable, and confirm the consent control and privacy link are present and correctly worded.

8 Appendix

8.1 Test coverage matrix

OWASP WSTG categories, with the result and — importantly — the reason where a category was not applicable. Categories marked N/A were confirmed absent, not skipped.

TEST CATEGORY	RESULT	NOTES
Information gathering	COMPLETE	Routes, headers, assets and technology fingerprint enumerated
Configuration & deployment	FINDINGS	VAPT-01, VAPT-05, VAPT-06
Identity management	N/A	No user accounts or registration exist
Authentication	N/A	No authentication mechanism exists
Authorization	N/A	No privilege model; all content is public
Session management	N/A	No cookies or sessions issued — verified via response headers
Input validation	PASS	No injection sink reachable; input never leaves the browser
Cross-site scripting	INFO	Single sink reviewed and found non-exploitable — VAPT-07
SQL / NoSQL / command injection	N/A	No datastore, no server-side execution
Error handling	PASS	404 returns a standard page; no stack traces or path disclosure
Cryptography & transport	PASS	HTTP/2, valid certificate, HSTS preloaded, HTTPS enforced
Business logic	FINDING	VAPT-02 — forms discard all submissions
Client-side testing	INFO	VAPT-07, VAPT-08; no DOM XSS or open redirect found
CSRF	N/A	No state-changing request and no cookie-based authentication
File upload	N/A	No upload capability exists
Software composition	FINDINGS	VAPT-04 — build-time advisories
Secret management	PASS	Clean in working tree and across full git history
Privacy & data protection	FINDING	VAPT-03 — no notice or consent
API security (Top 10:2023)	N/A	No API exists — absence verified, Section 3.2
Mobile security (MASVS v2)	N/A	No mobile app exists — absence verified, Section 3.3

8.2 Tooling

TOOL	PURPOSE
curl 8.x	HTTP header inspection, path enumeration, TLS verification
bun audit / npm audit	Software composition analysis against the GitHub Advisory Database
git	Full-history secret and sensitive-file review across all branches
grep / find	Static source analysis — injection sinks, secrets, framework detection
strings	PDF metadata extraction from published documents
Manual source review	Business-logic analysis of all 37 source files

8.3 Assessment limitations

- **Point-in-time.** Findings reflect commit `a4f4020` and the live deployment as observed on 17 August 2026. Subsequent changes are not covered.
- **Preview environment.** Testing targeted the Vercel deployment at `re-new-mocha.vercel.app`. If the site is later served from `renew.com` — behind a WAF, a CDN, or different edge configuration — the header findings in particular must be re-verified against that environment.
- **Non-intrusive testing only.** No automated scanner, fuzzer or exploit was run against the live host. Given the absence of any server-side execution, dynamic exploitation testing had no applicable target.
- **Platform trust.** Vercel's edge infrastructure, TLS termination and build environment were treated as trusted and were not assessed.
- **Third-party destinations.** External domains linked from the site were catalogued but not tested, being outside the authorised scope.

8.4 Glossary

TERM	MEANING
VAPT	Vulnerability Assessment and Penetration Testing
CVSS	Common Vulnerability Scoring System v3.1 — standardised severity scoring
CWE	Common Weakness Enumeration — a taxonomy of software weakness types
CSP	Content Security Policy — a header restricting the resources a page may load
HSTS	HTTP Strict Transport Security — forces browsers to use HTTPS
SCA	Software Composition Analysis — scanning dependencies for known vulnerabilities
Static export	A build that produces only static files, with no server-side runtime
Clickjacking	Framing a site invisibly to trick users into interacting with it unknowingly
DPDP Act	India's Digital Personal Data Protection Act, 2023
MASVS	OWASP Mobile Application Security Verification Standard

END OF REPORT

ReNew Solar Marketing Website — VAPT Report v1.0 — 17 August 2026. 9 findings: 0 Critical, 1 High, 3 Medium, 2 Low, 3 Informational. Overall risk posture: **Low**. Retest recommended after roadmap items 1–5.